

AI Procurement Review Checklist

A practical, client-ready checklist for evaluating AI tools, AI-enabled vendors, and AI procurement decisions before purchase, renewal, or expansion.

Purpose

Use this checklist to confirm that business need, security, privacy, legal, procurement, operational, and AI-specific governance requirements have been reviewed before an AI product is purchased, renewed, materially changed, or broadly deployed.

Document Type	Operational Checklist	Version	1.0	Owner	AI GOVERNANCE LEAD
Review Cycle	At least annually or upon major AI procurement change	Related Artifact	AI Vendor Risk Review	Primary Users	Procurement, IT, Security, Privacy, Legal, Business Owner
Status	Draft / Approved / In Use	Scope	AI tools, AI-enabled SaaS, copilots, model APIs, embedded AI features	Trigger	New purchase, renewal, upgrade, high-risk change

How to use this checklist

- Use it before a new AI vendor is purchased, before an existing vendor adds material AI features, or before an AI contract is renewed.
- Complete the sections in order and capture evidence in the Notes / evidence column.
- Escalate any item that cannot be confirmed, any answer that introduces high-risk data or decisions, or any vendor that refuses to provide reasonable assurance evidence.
- This checklist supports procurement review; it does not replace detailed security, privacy, legal, or architecture review where required.

1. Initiate the procurement review

Confirm that the AI purchase is in scope and that the request has a named business owner, a real need, and a review trigger.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Confirm the procurement trigger.	Identify whether the review is for a new purchase, renewal, expansion, pilot, or material feature change.	Request ticket, business memo, or intake link.
☐	Assign a business owner and reviewer set.	Name the business sponsor plus procurement, IT, security, privacy, legal, and operations contacts as needed.	Owner list and review routing.
☐	Describe the business problem to be solved.	State the operational need, why AI is being considered, and what success should look like.	Problem statement or use-case summary.
☐	Check for duplicate or already-approved tools.	Confirm whether an approved platform already provides equivalent capability.	Existing-tool review or architecture note.
☐	Set the target decision date.	Define when procurement needs a go / no-go decision and what must be reviewed before then.	Timeline and dependencies.

2. Confirm the business case and sponsorship

Make sure the purchase has a clear sponsor, defined value, intended users, and a realistic rollout plan.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Define expected business value.	Capture the expected benefit such as productivity, quality, speed, revenue enablement, customer support, or risk reduction.	Business case, ROI estimate, or expected KPI.
☐	Identify intended users and functions.	List which teams, roles, or geographies will use the tool and whether usage is optional or required.	User groups and volume estimate.
☐	Clarify whether the use is internal or external.	Confirm whether outputs are only for internal support or whether customers, partners, or applicants may be affected.	Use-case description.
☐	Identify decision impact.	Confirm whether the tool influences hiring, finance, legal, customer decisions, safety, or regulated activities.	Impact statement and escalation flags.
☐	Confirm executive or functional sponsorship.	Verify that an accountable leader supports the purchase and accepts ownership of the business outcome.	Named sponsor and approval.

3. Profile the vendor, product, and deployment model

Understand exactly what is being bought, how it works, and where it fits in the environment.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Record the full vendor and product name.	Capture the legal vendor name, product name, edition, and licensing model.	Quote, order form, or vendor profile.
☐	Describe the AI capability being purchased.	State whether the solution uses embedded AI, third-party foundation models, custom models, agent workflows, copilots, or model APIs.	Product description or architecture note.
☐	Identify deployment and hosting model.	Confirm whether the service is SaaS, API-based, browser-based, desktop, mobile, or on-prem/hybrid.	Vendor documentation.
☐	Identify integrations and dependencies.	List connected systems, plug-ins, browser extensions, identity requirements, or data sources the tool will use.	Integration map.
☐	Confirm data residency and service footprint.	Document where the service is hosted and which regions process or store data.	Vendor statement or contract exhibit.

4. Review data handling and privacy expectations

AI purchases often fail here. Confirm what data goes in, what data comes out, and what the vendor is allowed to do with it.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	List all planned data inputs.	Identify whether prompts or datasets may contain public, internal, confidential, personal, regulated, or customer data.	Data profile or sample use cases.
☐	Check for prohibited or restricted data.	Confirm whether highly sensitive data categories are in scope and whether policy allows them in this platform.	Policy cross-check and data classification.
☐	Verify vendor data use terms.	Confirm whether customer inputs, outputs, logs, or files are used for model training, fine-tuning, service improvement, or retained beyond business need.	DPA, privacy terms, or vendor FAQ.
☐	Confirm deletion and retention behavior.	Understand how long prompts, uploads, logs, and outputs are retained and how deletion is requested.	Retention schedule or contract clause.
☐	Check privacy and cross-border requirements.	Determine whether a DPIA, DPA, SCCs, or other privacy review is required before use.	Privacy review notes and legal requirements.

Common failure point: teams assume 'enterprise' means data will never be retained or used for training. Verify it in writing.

5. Review security, identity, and access controls

Do not buy a clever AI tool that behaves like an unlocked side door.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Confirm identity and authentication options.	Check SSO, MFA, federation, SCIM, role-based access control, and support for managed identities or service accounts.	Security questionnaire and admin docs.
☐	Review access model and least privilege.	Confirm whether roles can be restricted by function, workspace, project, dataset, or admin capability.	Role matrix or admin screenshots.
☐	Assess encryption and key protections.	Check encryption in transit and at rest, plus any options for customer-managed keys or private networking where relevant.	Security whitepaper.
☐	Review logging, alerting, and admin visibility.	Confirm whether admins can review usage, monitor access, export logs, and support investigations.	Audit log documentation.
☐	Check assurance evidence.	Collect relevant SOC reports, ISO certifications, penetration testing summaries, or equivalent assurance artifacts.	Evidence package.

6. Assess AI-specific governance and model risk

This is the section most vendors hope you skip. Do not grant that wish.

Check	Required step or confirmation	What should be covered	Notes / evidence
[]	Confirm model transparency.	Understand whether the vendor discloses which model families are used, whether model providers may change, and what notice is given for material changes.	Product documentation or written response.
[]	Review output reliability safeguards.	Check whether the tool supports human review, confidence indicators, grounded retrieval, policy controls, or other mechanisms that reduce harmful output use.	Feature list or governance docs.
[]	Identify automation level.	Confirm whether the product only assists humans or whether it can trigger actions, decisions, communications, or workflow execution automatically.	Workflow description.
[]	Check for bias, fairness, or sensitive-use concerns.	Determine whether the tool could create discriminatory or inappropriate outcomes in HR, finance, legal, healthcare, education, or other sensitive contexts.	Use-case and legal review notes.
[]	Define required human oversight.	State what human review is required before outputs are relied upon, especially for customer-facing or high-impact decisions.	Operating procedure or control note.

Escalation rule: if the tool influences high-impact decisions or automates actions, require explicit human oversight and formal sign-off.

7. Review commercial, legal, and contractual terms

Procurement should not sign a contract that quietly gives away your data, leverage, or exit options.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Review contract structure and pricing.	Understand license metrics, overage risk, API usage pricing, pilot conversion terms, and renewal behavior.	Quote and order form.
☐	Confirm security and privacy commitments in contract.	Make sure commercial terms align with the security and privacy promises made during review.	MSA, DPA, security schedule.
☐	Check service levels and support obligations.	Review uptime commitments, response targets, support model, and escalation paths.	SLA and support terms.
☐	Assess incident notification and cooperation terms.	Confirm whether the contract requires timely incident notice, investigation support, and remediation obligations.	Security addendum or MSA clause.
☐	Review termination, data return, and deletion rights.	Check what happens at exit, including data portability, deletion, and dependency unwind.	Termination and data handling clauses.

8. Confirm implementation readiness and operating controls

A tool is not ready because the sales demo sparkled. Confirm it can actually be governed in production.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Identify implementation owner and rollout path.	Define who will configure, test, deploy, and support the solution after purchase.	Implementation plan.
☐	Document required safeguards before go-live.	List conditions such as approved data boundaries, configured SSO, logging, admin roles, policy training, or restricted pilot scope.	Go-live checklist.
☐	Plan user guidance and training.	Confirm that employees will receive acceptable use guidance, escalation channels, and any role-based instructions.	Training plan or comms draft.
☐	Define ongoing review triggers.	Set when the solution must be re-reviewed, such as vendor feature changes, new integrations, sensitive data use, or expanded automation.	Review cadence and triggers.
☐	Confirm registry and recordkeeping updates.	Ensure the purchase and associated use cases will be entered into the AI use case registry or vendor inventory.	Registry owner and entry plan.

Minimum go-live expectation: approved identity setup, defined owner, documented safeguards, user guidance, and registry entry.

9. Finalize the decision and procurement handoff

Close the loop with a clear decision, conditions, and accountable owners.

Check	Required step or confirmation	What should be covered	Notes / evidence
☐	Summarize residual risks.	List open issues, accepted risks, compensating controls, and decisions still pending.	Risk summary.
☐	Record the procurement decision.	Mark approved, approved with conditions, deferred, pilot only, or rejected.	Decision record.
☐	Capture conditions for approval.	State what must happen before contract signature, before pilot, and before full production use.	Condition list.
☐	Assign action owners and due dates.	Name who owns each follow-up item, including procurement, security, business, IT, or legal.	Action tracker.
☐	Store review evidence.	Save the completed checklist and supporting evidence in the approved repository.	Document location and retention owner.

10. Approval and control record

Complete this summary after the checklist review is finished and the procurement decision is made.

Prepared by	{{PROCUREMENT_OR_REQU EST_OWNER}}	Date	{{DATE}}
Reviewed by	{{REVIEWER_NAME}}	Decision	APPROVED / APPROVED WITH CONDITIONS / DEFERRED / REJECTED
Registry ID	{{REGISTRY_ID}}	Risk Review Date	{{DATE}}
Evidence Location	{{REPOSITORY_LINK_OR_PA TH}}	Next Review Trigger	{{EVENT}}